Critical Infrastructure Security

IY5612 (IY3612/IY4612) — Academic Year 2025/2026 (Unit 5)

Stephen D. Wolthusen
stephen.wolthusen@rhul.ac.uk

Department of Information Security and Communication Technology
Norwegian University of Science and Technology, Norway

and

Department of Information Security
Royal Holloway, University of London, United Kingdom

Unit 5— Attacking Power Systems

Contents

Power Systems: A CI Case Study

Attacking Power Systems

Attacking Power Systems

Part II

Attacking Power Systems

Introduction

Power networks and power systems have been the target of state actors for well over a decade

- Attacks against ICS systems date back to the 1980s, but the Olympic Games programme brought this to the attention of a wider audience
- Many nation states have been openly acknowledging that they seek to compromise and subvert power networks and other critical infrastructure systems
- New demands on distribution and transmission grids such as increased dynamicity, interconnections, and integration of distributed generation or storage increase the need for automation, faster sensing cycles — and reduce the ability to compensate manually

Most activity has been limited to reconnaissance and placement of back doors or monitoring systems, limiting the visible impact for operators

Visible Artefacts

Major players have been inside one another's power systems for years, but a recently leaked report is the equivalent of "gunboat diplomacy" with the U.S. effectively acknowledging that it has subverted parts of the Russian Federation's power systems with offensive malware in place: U.S. Escalates Online Attacks on Russia's Power Grid (New York Times, 15 June 2019)

Energy companies are a mainstay of attacks, and attacks are successful quite often

- Even looking only at unclassified information from ICS-CERT, E-ISAC, and the biannual U.S. NERC Grid Security (GridEx) exercises, there is a high density of (successful) attacks
- Knowledge of vulnerabilities existed at least since the days of Eligible Receiver 1997, and attacks range up and down the supply chain
- Regular exercises still show plenty of work to be done – and crises such as the current one over Ukraine lead to enhanced readiness of both offensive and defensive roles

A Simple, Effective Attack

Ukraine and particularly its power system give the appearance of having been used as a “living laboratory” for cyber-physical attacks

- A group deploying malware sometimes known as “Sandworm” has been active since at least 2015 (and is still active with growing tool set)
- A first attack, heavily reported in Western media in late 2015 relied on an adapted version of the generic BlackEnergy malware (RAT and DDoS bot) that had been around since 2007
- This attack was not particularly sophisticated from a control systems perspective; after a spear phishing attack it mostly consisted of taking over the HMI remotely
- Actual damage was modest with around 200’000 customers affected
- The “rustic” control system in use was helpful as operators could resort to manual operation: Manhandling switchgear instructed by telephone

Practice Makes Perfect

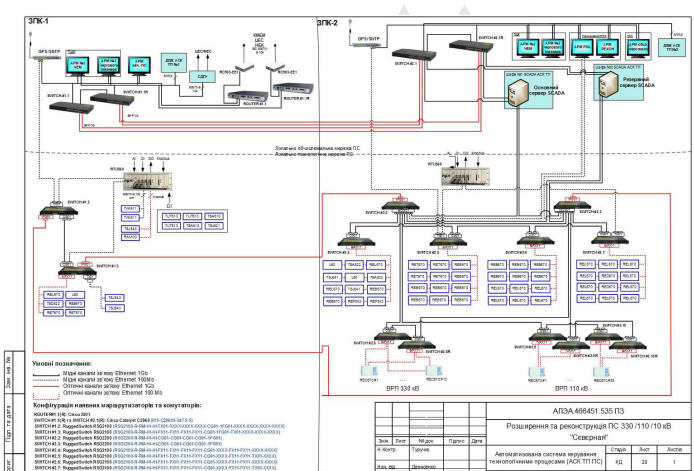
On 17 December 2016 at 11:53pm, the “Poltava” transmission grid substation at Pivnichna (330kV) was disconnected without warning

- This affected parts of Kiev, substation was re-connected at 1:05am
- The substation had been recently refurbished in 2012–2014 and equipped with modern automation components running ABB, GE, and Siemens equipment using IEC61850 communication controlled by a MicroSCADA Pro 9.3 environment
- Helpfully, Enpaselectro Ltd. had posted detailed designs online — and remarkably, (cyber) security was not part of the requirements set

Source: Ukrenergo

“Open Access” Is Not Always Helpful

Substation Architecture



Source: Epaselectro

Exploiting Lessons Learned (1)

The cause for the fault was not equipment failure, but the Sandworm group coming back for more a year later, targeting the ICS system itself:

- The entry point (Crash Override/Industroyer) was again a straightforward RAT with C2 and backdoor features, but with the ability to launch attacks against process networks and protocols
- The malware had payload for most standard communication protocols in power systems: IEC 60870-5-101, -104, IEC 61850 and OPC DA
- Both pre-programmed and manually remote controlled operation was possible

Exploiting Lessons Learned (2)

Attackers had also thought about ensuring that mitigation and recovery would not be too straightforward:

- Another component targeted the ABB MicroScada software to deny operators the ability to recover, then wiping and crashing systems for good measure

Industroyer was also able to exploit a vulnerability in the SIPROTEC protective relays (since patched) that would have disabled protective breakers: Counting on operator manual overrides (as used in 2015 to recover) to destroy equipment

Exploiting Lessons Learned (3)

Sandworm and colleagues have been continuously active,

- The PIPEDREAM malware associated with Sandworm (discovered in 2022) has a fairly extensive tool set in place allowing automation of many attacks and capabilities to target OT component protocols directly without users necessarily needing in-depth knowledge
- Interestingly, PIPEDREAM had the capability to also target safety instrumentation systems, even though this was apparently not exploited
- The tool set was then first seen in attacks in the ELECTRUM breach of the Ukrainian power grid in late 2022
- In October 2025 a large-scale attack against the Polish power grid seems to have emanated from the (domestic!) FSB — however, attacks against substations used generic wipers rather than the custom exploit kit used by Sandworm

Summary

This section provided material on

- Power systems as a target of attacks
- Case study: Ukrainian power network attacks